

linux服务器基本安全配置手册

笔记本：linux加固

创建时间：2018/11/1 14:36

更新时间：2018/11/1 14:37

作者：苏醒

URL：<https://www.jb51.net/article/29873.htm>

安装注意

1.删除系统特殊的用户帐号：

禁止所有默认的被操作系统本身启动的且不需要的帐号，当你第一次装上系统时就应该做此检查，Linux提供了各种帐号，你可能不需要，如果你不需要这个帐号，就移走它，你有的帐号越多，就越容易受到攻击。

```
#为删除你系统上的用户，用下面的命令：
[root@c1gstudio]# userdel username
#批量删除方式
#这里删除"adm lp sync shutdown halt mail news uucp operator games gopher ftp "账号
#如果你开着ftp等服务可以把ftp账号保留下来。
for i in adm lp sync shutdown halt mail news uucp ope
rator games gopher ftp ;do userdel $i ;done
```

2.删除系统特殊的组帐号

```
[root@c1gstudio]# groupdel groupname
#批量删除方式
for i in adm lp mail news uucp games dip pppusers pop
users slipusers ;do groupdel $i ;done
```

3.用户密码设置

安装linux时默认的密码最小长度是5个字节，但这并不够，要把它设为8个字节。修改最短密码长度需要编辑login.defs文件#vi /etc/login.defs

```
PASS_MAX_DAYS 99999 ##密码设置最长有效期（默认值）
PASS_MIN_DAYS 0 ##密码设置最短有效期
PASS_MIN_LEN 5 ##设置密码最小长度，将5改为8
PASS_WARN_AGE 7 ##提前多少天警告用户密码即将过期。
然后修改Root密码
#passwd root
New UNIX password:
Retype new UNIX password:
passwd: all authentication tokens updated successfully.
```

4.修改自动注销帐号时间

自动注销帐号的登录，在Linux系统中root账户是具有最高特权的。如果系统管理员在离开系统之前忘记注销root账户，那将会带来很大的安全隐患，应该让系统会自动注销。通过修改账户中“TMOUT”参数，可以实现此功能。TMOUT按秒计算。编辑你的profile文件（vi /etc/profile），在“HISTSIZE=”后面加入下面这行：

TMOUT=300

300，表示300秒，也就是表示5分钟。这样，如果系统中登陆的用户在5分钟内都没有动作，那么系统会自动注销这个账户。

5.限制Shell命令记录大小

默认情况下，bash shell会在文件\$HOME/.bash_history中存放多达500条命令记录(根据具体的系统不同，默认记录条数不同)。系统中每个用户的主目录下都有一个这样的文件。在此笔者强烈建议限制该文件的大小。

您可以编辑/etc/profile文件，修改其中的选项如下：

```
HISTFILESIZE=30或HISTSIZE=30
#vi /etc/profile
HISTSIZE=30
```

6.注销时删除命令记录

编辑/etc/skel/.bash_logout文件，增加如下行：

```
rm -f $HOME/.bash_history
```

这样，系统中的所有用户在注销时都会删除其命令记录。

如果只需要针对某个特定用户，如root用户进行设置，则可只在该用户的主目录下修改/\$HOME/.bash_history文件，增加相同的一行即可。

7.用下面的命令加需要的用户组和用户帐号

```
[root@c1gstudio]# groupadd
例如：增加website 用户组，groupadd website
然后调用vigr命令查看已添加的用户组
用下面的命令加需要的用户帐号
[root@c1gstudio]# useradd username -g website //添加用户到website组（作为webserver的普通
管理员，而非root管理员）
然后调用vipw命令查看已添加的用户
用下面的命令改变用户口令（至少输入8位字母和数字组合的密码，并将密码记录于本地机的专门文档
中，以防遗忘）
[root@c1gstudio]# passwd username
```

8.阻止任何人su作为root

如果你不想任何人能够su作为root,你能编辑/etc/pam.d/su加下面的行：

```
#vi /etc/pam.d/su
auth sufficient /lib/security/$ISA/pam_rootok.so debug
auth required /lib/security/$ISA/pam_wheel.so group=website
意味着仅仅website组的用户可以su作为root.
```

9.修改ssh服务的root登录权限

修改ssh服务配置文件，使的ssh服务不允许直接使用root用户来登录，这样减少系统被恶意登录攻击的机会。

```
#vi /etc/ssh/sshd_config
PermitRootLogin yes
```

将这行前的 # 去掉后，修改为：

```
PermitRootLogin no
```

10.修改ssh服务的sshd 端口

ssh默认会监听在22端口，你可以修改至6022端口以避过常规的扫描。

注意：修改端口错误可能会导致你下次连不到服务器，可以先同时开着22和6022两个端口，然后再关掉22端口；

重启sshd不会弹掉你当前的连接，可以另外开一个客户端来测试服务；

```
#vi /etc/ssh/sshd_config
#增加修改
#Port 22 #关闭22端口
Port 6022 #增加6022端口
#重启sshd服务
service sshd restart
检查一下sshd的监听端口对不对
netstat -lnp|grep ssh
#iptables开放sshd的6022端口
vi /etc/sysconfig/iptables
#如果使用redhat默认规则则增加
-A RH-Firewall-1-INPUT -m state --state NEW -m tcp -p tcp --dport 6022 -j ACCEPT
#或
iptables -A INPUT -p tcp --dport 6022 -j ACCEPT
iptables -A OUTPUT -p udp --sport 6022 -j ACCEPT
```

重启iptables 服务

```
service iptables restart
#测试两个端口是否都能连上，连上后再将22端口删除
```

详细参考：

Linux操作系统下SSH默认22端口修改方法

11.关闭系统不使用的服务：

cd /etc/init.d #进入到系统init进程启动目录

在这里有两个方法，可以关闭init目录下的服务，

一、将init目录下的文件名mv成*.old类的文件名，即修改文件名，作用就是在系统启动的时候找不到这个服务的启动文件。

二、使用chkconfig系统命令来关闭系统启动等级的服务。

注：在使用以下任何一种方法时，请先检查需要关闭的服务是否是本服务器特别需要启动支持的服务，以防关闭正常使用的服务。

使用chkconfig命令来关闭不使用的系统服务 (level前面为2个减号)要想在修改启动脚本前了解有多少服务正在运行，输入：

```
ps aux | wc -l
```

然后修改启动脚本后，重启系统，再次输入上面的命令，就可计算出减少了多少项服务。越少服务在运行，安全性就越好。另外运行以下命令可以了解还有多少服务在运行：

```
netstat -na --ip
```

批量方式先停止服务

```
for i in acpid anacron apmd atd auditd autofs avahi-daemon avahi-dnscnf bluetooth cpuspeed cups dhcpd firstboot gpm haldaemon hidd ip6tables ipsec isdn kudzu lpd mcstrans messagebus microcode_ctl netfs nfs nfslock nsd pcscd portmap readahead_early restorecond rpcgssd rpcidmapd rstatd sendmail
```

```
do service $i stop;done
```

关闭启动服务

```
for i in acpid anacron apmd atd auditd autofs avahi-daemon avahi-dnscnf bluetooth cpuspeed cups dhcpd firstboot gpm haldaemon hidd ip6tables ipsec isdn kudzu lpd mcstrans messagebus microcode_ctl netfs nfs nfslock nsd pcscd portmap readahead_early restorecond rpcgssd rpcidmapd rstatd sendmail
```

```
do chkconfig $i off;done
```

以下为手动方式及解释,执行批量方式后不需再执行了

```
chkconfig --level 345 apmd off ##笔记本需要
chkconfig --level 345 netfs off ## nfs客户端
chkconfig --level 345 yppasswdd off ## NIS服务器，此服务漏洞很多
chkconfig --level 345 ypserv off ## NIS服务器，此服务漏洞很多
chkconfig --level 345 dhcpd off ## dhcp服务
chkconfig --level 345 portmap off ##运行rpc(111端口)服务必需
chkconfig --level 345 lpd off ##打印服务
chkconfig --level 345 nfs off ## NFS服务器，漏洞极多
chkconfig --level 345 sendmail off ##邮件服务, 漏洞极多
chkconfig --level 345 snmpd off ## SNMP，远程用户能从中获得许多系统信息
chkconfig --level 345 rstatd off ##避免运行r服务，远程用户可以从中获取很多信息
chkconfig --level 345 atd off ##和cron很相似的定时运行程序的服务
注：以上chkconfig 命令中的3和5是系统启动的类型，以下为数字代表意思
0:开机(请不要切换到此等级)
1:单人使用者模式的文字界面
2:多人使用者模式的文字界面,不具有网络档案系统(NFS)功能
3:多人使用者模式的文字界面,具有网络档案系统(NFS)功能
4:某些发行版的linux使用此等级进入x windows system
5:某些发行版的linux使用此等级进入x windows system
6:重新启动
```

如果不指定--level 单用on和off开关，系统默认只对运行级3，4，5有效

```
chkconfig cups off #打印机
```

```
chkconfig bluetooth off # 蓝牙
chkconfig hidd off # 蓝牙
chkconfig ip6tables off # ipv6
chkconfig ipsec off # vpn
chkconfig auditd off #用户空间监控程序
chkconfig autofs off #光盘软盘硬盘等自动加载服务
chkconfig avahi-daemon off #主要用于Zero Configuration Networking , 一般没什么用建议关闭
chkconfig avahi-dnssd off #主要用于Zero Configuration Networking ,同上,建议关闭
chkconfig cpuspeed off #动态调整CPU频率的进程, 在服务器系统中这个进程建议关闭
chkconfig isdn off #isdn
chkconfig kudzu off #硬件自动监测服务
chkconfig nfslock off #NFS文档锁定功能。文档共享支持, 无需求关了
chkconfig nscd off #负责密码和组的查询, 在有NIS服务时需要
chkconfig pcsd off #智能卡支持, 如果没有可以关了
chkconfig yum-updatesd off #yum更新
chkconfig acpid off
chkconfig autofs off
chkconfig firstboot off
chkconfig mcstrans off #selinux
chkconfig microcode_ctl off
chkconfig rpcgssd off
chkconfig rpcidmapd off
chkconfig setroubleshoot off
chkconfig xfs off
chkconfig xinetd off
chkconfig messagebus off
chkconfig gpm off #鼠标
chkconfig restorecond off #selinux
chkconfig haldaemon off
chkconfig sysstat off
chkconfig readahead_early off
chkconfig anacron off
```

需要保留的服务

```
| crond , irqbalance , microcode_ctl , network , sshd , syslog
```

因为有些服务已运行, 所以设置完后需重启

```
| chkconfig
| /*
```

语法: `chkconfig [--add][--del][--list][系统服务]` 或 `chkconfig [--level <等级代号>][系统服务][on/off/reset]`

补充说明: 这是Red Hat公司遵循GPL规则所开发的程序, 它可查询操作系统在每一个执行等级中会执行哪些系统服务, 其中包括各类常驻服务。

参数:

```
| --add 增加所指定的系统服务, 让chkconfig指令得以管理它, 并同时在系统启动的叙述文件内增加
| 相关数据。
```

```
--del 删除所指定的系统服务，不再由chkconfig指令管理，并同时在系统启动的叙述文件内删除相关数据。  
--level<等级代号> 指定读系统服务要在哪一个执行等级中开启或关毕  
*/
```

12.阻止系统响应任何从外部/内部来的ping请求

既然没有人能ping通你的机器并收到响应，你可以大大增强你的站点的安全性。你可以加下面的一行命令到/etc/rc.d/rc.local，以使每次启动后自动运行。

```
echo 1 > /proc/sys/net/ipv4/icmp_echo_ignore_all  
#这个可以不做哈
```

13.修改"/etc/host.conf"文件

```
"/etc/host.conf" 说明了如何解析地址。编辑 "/etc/host.conf" 文件 ( vi /etc/host.conf )，加入下面这行：  
# Lookup names via DNS first then fall back to /etc/hosts.  
order hosts,bind  
# We have machines with multiple IP addresses.  
multi on  
# Check for IP address spoofing.  
nospoof on
```

第一项设置首先通过DNS解析IP地址，然后通过hosts文件解析。第二项设置检测是否"/etc/hosts"文件中的主机是否拥有多个IP地址（比如有多个以太网网卡）。第三项设置说明要注意对本机未经许可的电子欺骗。

14.不允许从不同的控制台进行root登陆

"/etc/securetty"文件允许你定义root用户可以从那个TTY设备登陆。你可以编辑"/etc/securetty"文件，再不需要登陆的TTY设备前添加"#"标志，来禁止从该TTY设备进行root登陆。

在/etc/inittab文件中有如下一段话：

```
# Run gettys in standard runlevels  
1:2345:respawn:/sbin/mingetty tty1  
2:2345:respawn:/sbin/mingetty tty2  
#3:2345:respawn:/sbin/mingetty tty3  
#4:2345:respawn:/sbin/mingetty tty4  
#5:2345:respawn:/sbin/mingetty tty5  
#6:2345:respawn:/sbin/mingetty tty6
```

系统默认的可以使用6个控制台，即Alt+F1,Alt+F2...，这里在3，4，5，6前面加上"#"，注释该句话，这样现在只有两个控制台可供使用，最好保留两个。然后重新启动init进程，改动即可生效！

15.禁止Control-Alt-Delete键盘关闭命令

```
在"/etc/inittab" 文件中注释掉下面这行（使用#）：  
ca::ctrlaltdel:/sbin/shutdown -t3 -r now  
改为：
```

```
#ca::ctrlaltdel:/sbin/shutdown -t3 -r now
为了使这项改动起作用，输入下面这个命令：
# /sbin/init q
```

16.用chattr命令给下面的文件加上不可更改属性。

```
[root@c1gstudio]# chattr +i /etc/passwd
[root@c1gstudio]# chattr +i /etc/shadow
[root@c1gstudio]# chattr +i /etc/group
[root@c1gstudio]# chattr +i /etc/gshadow
```

【注：chattr是改变文件属性的命令，参数i代表不得任意更动文件或目录,此处的i为不可修改位(immutable)。查看方法：lsattr /etc/passwd，撤销为chattr -i /etc/group】

补充说明：这项指令可改变存放在ext2文件系统上的文件或目录属性，这些属性共有以下8种模式：

- a：让文件或目录仅供附加用途。
- b：不更新文件或目录的最后存取时间。
- c：将文件或目录压缩后存放。
- d：将文件或目录排除在倾倒操作之外。
- i：不得任意更动文件或目录。
- s：保密性删除文件或目录。
- S：即时更新文件或目录。
- u：预防以外删除。

参数：

- R 递归处理，将指定目录下的所有文件及子目录一并处理。
- v<版本号> 设置文件或目录版本。
- V 显示指令执行过程。
- +<属性> 开启文件或目录的该项属性。
- <属性> 关闭文件或目录的该项属性。
- =<属性> 指定文件或目录的该项属性。

17.给系统服务端口列表文件加锁

主要作用：防止未经许可的删除或添加服务

```
chattr +i /etc/services
【查看方法：lsattr /etc/ services，撤销为chattr -i /etc/ services】
```

18.系统文件权限修改

Linux文件系统的安全主要是通过设置文件的权限来实现的。每一个Linux的文件或目录，都有3组属性，分别定义文件或目录的所有者，用户组和其他人的使用权限（只读、可写、可执行、允许SUID、允许SGID等）。特别注意，权限为SUID和SGID的可执行文件，在程序运行过程中，会给进程赋予所有者的权限，如果被黑客发现并利用就会给系统造成危害。

(1)修改init目录文件执行权限：


```
chmod -R 700 /etc/init.d/* (递归处理, owner具有rwx, group无, others无)
```

(2)修改部分系统文件的SUID和SGID的权限：

```
chmod a-s /usr/bin/chage
chmod a-s /usr/bin/gpasswd
chmod a-s /usr/bin/wall
chmod a-s /usr/bin/chfn
chmod a-s /usr/bin/chsh
chmod a-s /usr/bin/newgrp
chmod a-s /usr/bin/write
chmod a-s /usr/sbin/usernetctl
chmod a-s /usr/sbin/traceroute
chmod a-s /bin/mount
chmod a-s /bin/umount
chmod a-s /sbin/netreport
```

(3)修改系统引导文件

```
chmod 600 /etc/grub.conf
chattr +i /etc/grub.conf
【查看方法：lsattr /etc/grub.conf, 撤销为chattr -i /etc/grub.conf】
```

19.增加dns

```
#vi /etc/resolv.conf
nameserver 8.8.8.8 #google dns
nameserver 8.8.4.4
```

20.hostname 修改

```
#注意需先把mysql、postfix等服务停了
1.hostname servername
2.vi /etc/sysconfig/network
service network restart
3.vi /etc/hosts
```

21.selinux 修改

开启selinux可以增加安全性, 但装软件时可能会遇到一些奇怪问题

以下是关闭方法

```
#vi /etc/selinux/config
```

改成disabled

22.关闭ipv6

```
echo "alias net-pf-10 off" >> /etc/modprobe.conf
echo "alias ipv6 off" >> /etc/modprobe.conf
#vi /etc/sysconfig/network
NETWORKING_IPV6=no
```

重启服务


```
Service ip6tables stop
Service network restart
```

关闭自动启动

```
chkconfig --level 235 ip6tables off
```

23.设置iptables

iptables 默认安全规则脚本

重启系统

以上大部分设置可以运行脚本来完成。linux安全设置快捷脚本

设置完成后重启系统

其它设置项

linux调整系统时区/时间的方法

把/usr/share/zoneinfo里相应的时区与/etc/localtime做个软link.比如使用上海时区的时间:ln -s

/usr/share/zoneinfo/Asia/Shanghai /etc/localtime 如果要使用UTC计时方式,则应在/etc/sysconfig/clock文件里改

UTC=TRUE 时间的设置: 使用date 命令加s参数修改, 注意linux的时间格式为"月日時分年",也可以只修改时间date -s

22:30:20,如果修改的是年月日和时间, 格式为"月日時分年.秒",2007-03-18 11:01:56则应写为"date -s

031811012007.56 硬件时间与当前时间更新: hwclock --systohc 如果硬件计时用UTC,则为 hwclock --systohc --utc

linux调整系统时区/时间的方法

1) 找到相应的时区文件

```
/usr/share/zoneinfo/Asia/Shanghai
```

用这个文件替换当前的/etc/localtime文件。

步骤: cp -i /usr/share/zoneinfo/Asia/Shanghai /etc/localtime

选择覆盖

2) 修改/etc/sysconfig/clock文件, 修改为:

```
ZONE="Asia/Shanghai"
UTC=false
ARC=false
```

3)

时间设定成2005年8月30日的命令如下:

```
#date -s 08/30/2005
```

将系统时间设定成下午6点40分0秒的命令如下:

```
#date -s 18:40:00
```

4)同步BIOS时钟，强制把系统时间写入CMOS，命令如下：

```
#clock -w
```

安装ntpd

```
#yum install ntp  
#chkconfig --levels 235 ntpd on  
#ntpdate ntp.api.bz #先手动校准下  
#service ntpd start
```

设置语言

英文语言，中文支持

```
#vi /etc/sysconfig/i18n  
LANG="en_US.UTF-8"  
SUPPORTED="zh_CN.UTF-8:zh_CN:zh"  
SYSFONT="latarcyrheb-sun16"
```

tmpwatch 定时清除

假设服务器自定义了php的session和upload目录

```
#vi /etc/cron.daily/tmpwatch  
在240 /tmp 前增加  
-x /tmp/session -x /tmp/upload  
#mkdir /tmp/session  
#mkdir /tmp/upload  
#chown nobody:nobody /tmp/upload  
#chmod 0770 /tmp/upload
```